ACC-03 · MFA Enrollment, Reset & Account Recovery

How multifactor authentication is registered, how a person who cannot sign in is verified and restored, and how repeat incidents escalate.

Field	Value
Document ID	ACC-03
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Primary audience	All account holders for sections 5 and 7. Service desk and IT administrators for sections 6, 8, 9 and 10.
Review cycle	Every six months while the Entra migration is in progress, then annually.

1. Purpose

This procedure covers how a person registers multifactor authentication, how somebody who cannot sign in is verified and restored, and what happens when the same account fails repeatedly. It exists because account access is the largest single category of work on most service desks, and it is often handled without a documented decision path.

Before changing anything, measure your own desk over a recent few months:

Measure	Why it matters
Lockout tickets in the period	The headline number this document exists to bring down.
Of those, how many say “locked out” or “unlock”	Separates true lockouts from sign-in confusion.
Which population opens the most	Usually the least-managed group. It decides wave order in §11.
Share that were MFA problems	The share a better registration path removes.
Share that were password resets	The share self-service reset should absorb.
Median time to close	What a person locked out actually waits.

On many desks, identity and access is the largest share of genuine ticket volume, and most of it is absorbable by a documented self-service path and a triage card. Three patterns shape this document:

- A reset request arrives from a personal email address on behalf of a differently-named person, with no verification step recorded. That is the textbook help desk social-engineering vector, and section 6 is the control against it.

- A rushed rollout of phishing-resistant MFA breaks access and traps people in an MFA setup loop. Section 11 documents the usual cause and how to avoid it.
- A managed security partner asks which MFA system the organization uses, and the answer is not self-evident from anything written down. Section 3 fixes that.

---

2. Scope

In scope

- MFA registration, re-registration and method removal for every account class in ACC-01 §3.
- Password reset, both self-service and assisted.
- Account lockout and sign-in failure triage.
- Account recovery where the person has lost every registered method.
- Escalation of repeat lockouts and suspected account compromise.

Out of scope

- Password composition and expiry rules, which are in ACC-04.
- Privileged account authentication requirements, which are in ACC-07.
- Application-side MFA and claim configuration, which is in ACC-16.
- Formal incident declaration, which is in GOV-03. This procedure escalates into it.

---

3. Current state, target state and the cutover trigger

Many organizations are mid-migration between MFA systems or methods. Rather than write a procedure that is wrong now or wrong later, each affected section below states both. Where the two differ, the current-state text governs until the cutover trigger fires.

> **Read your tenant before you start, because it may change the urgency of this document**
>
> Check the authentication methods policy and your domains, read-only: in the Entra admin center, or with GET /v1.0/policies/authenticationMethodsPolicy and GET /v1.0/domains.
>
> IS ANY PHISHING-RESISTANT METHOD ENABLED? If FIDO2, certificate-based authentication and Windows Hello for Business are all off, every enabled method is phishable, and a vendor that starts enforcing phishing-resistant MFA will find nothing your people can register. Enabling a phishing-resistant method is then the first step of §11, not the last.
>
> ARE YOUR DOMAINS MANAGED OR FEDERATED? authenticationType=Managed means Microsoft Entra ID is the authentication authority. If a third-party identity provider also runs, write down which system authenticates whom and send it to any managed security partner, because a partner working from a wrong model of the estate is a risk in itself.
>
> WHICH WEAK METHODS ARE STILL ON? SMS and voice are SIM-swappable, and email as a factor is close to circular when the mailbox is what is being protected. Scope them out with the same wave discipline as everything else in §11.

3.1 Authentication methods: what to set

Method	Recommended setting	Assessment
Microsoft Authenticator	Enabled, with number matching	The workhorse. Phishable without number matching; confirm number matching is enforced.
Temporary Access Pass	Enabled	Correct, and a prerequisite for onboarding people onto passkeys (§11). Confirm the lifetime and one-time-use settings.
Software OATH token	Allowed as a fallback	Acceptable fallback. Phishable.
Voice call	Retire	WEAK. SIM-swappable and phishable.
Email OTP	Guests only	WEAK. Circular where the protected resource is the mailbox. Legitimate for guests only — scope it to guests rather than all users.
SMS	Disabled	Interceptable. Turn it off once people have something better.
FIDO2 security key	Enabled	Must be enabled before any population facing a phishing-resistant requirement can register anything that satisfies it.
X.509 certificate	Optional	The alternative phishing-resistant route if smart cards suit a population better than keys.
QR code PIN, Verifiable credentials	Only if needed	Rarely needed in a small shop.

If every method is targeted at all users, there is no per-population scoping yet. Section 11 depends on that scoping existing — building the wave groups is a prerequisite to the wave plan, not part of it.

Element	Current state — governs today	Target state — governs after cutover
Primary MFA system	A third-party identity provider may remain in force for some populations. IT must maintain, and publish, the authoritative list of which population authenticates through which system.	Microsoft Entra ID is the single MFA authority. Any third-party MFA is decommissioned.
Approved methods	Whatever your tenant read shows. Commonly Authenticator, software OATH, voice, email and TAP, with no phishing-resistant method — see §3.1.	Passkeys — Windows Hello for Business, platform credential, FIDO2 security key — and Authenticator passkey. Voice and email disabled or scoped to guests only.
Self-service password reset	Not consistently available. Most resets are assisted, which is why password resets fill so much of the queue.	Entra self-service password reset enabled for all account classes, with two registered methods required.
Recovery when all methods lost	Assisted reset after verification per section 6.	Temporary Access Pass issued after verification per section 6, forcing re-registration at next sign-in.
Conditional Access enforcement	Limited. No authentication-strength requirement in force.	Authentication strength “Phishing-resistant MFA”, rolled out in platform-based waves per section 11.

Cutover trigger

A population moves from current state to target state when all three of the following are true, and not before:

1. Every account in the wave group has at least one phishing-resistant method registered, evidenced from the Entra authentication-methods report.
2. A report-only Conditional Access policy has run over that group for at least ten business days with no unexplained would-be blocks.
3. The service desk has the section 6 verification script and the section 8 triage card in hand, and has run at least one rehearsal of the total-loss recovery path.

Known external constraint: where a vendor enforces phishing-resistant MFA by a date, that date drives the population using that vendor to the front of the wave order in section 11. It does not license skipping the three conditions above — rushing exactly that is what produces the setup loop.

4. Roles and responsibilities

Activity	Account holder	Service desk	IT admin	IT Security	Head of IT
Register two MFA methods on time	R / A	I	C	—	—
Verify identity before any account action (§6)	C	R / A	R	C	I
Perform an assisted reset or issue a TAP	—	R	R	I	—
Remove or re-register MFA methods	C	R	R / A	C	—
Triage a lockout (§8)	C	R / A	C	I	—
Escalate a repeat or suspected compromise (§9)	I	R	C	R / A	I
Act on a risky sign-in or impossible-travel alert (§10)	C	I	R	R / A	I
Approve a wave moving to enforcement (§11)	—	I	R	C	A
Approve any standing exception to MFA	—	—	C	C	A

5. MFA enrollment

5.1 Requirement by account class

Account class	Methods required	Deadline	Grace behaviour
Employee, staff (all)	Two, at least one phishing-resistant in target state	Within 24 hours of first sign-in	Blocked from all but registration after 5 days
User	Two	Within 7 days of first sign-in	Blocked from all but registration after 14 days

Account class	Methods required	Deadline	Grace behaviour
Temporary worker — departmental access	Two, registered separately from the user identity	Before departmental access is granted	Access not granted until registered
Vendor, contractor, guest	Two	Before first resource access	No access until registered
Administrative (privileged)	Phishing-resistant only. No SMS or voice, in either state.	Before the role is assigned	Role not assigned until registered (ACC-07)
Service / non-human	Not applicable — migrate to workload identity or certificate auth	—	See ACC-08

5.2 Approved and prohibited methods

Method	Status	Notes
Windows Hello for Business / platform credential	Preferred	Phishing-resistant. Requires the device to be Entra-joined and compliant (DEV-01, DEV-02).
Passkey in Microsoft Authenticator	Preferred	Phishing-resistant. Requires Android 14+, iOS 17+ or Windows 10 1903+ and a WebAuthn-capable browser. Devices below those versions need a different method — plan for it rather than discovering it during a wave.
FIDO2 security key	Preferred	Phishing-resistant. The answer for shared-use staff, lab staff and anyone whose device cannot carry a platform credential.
Microsoft Authenticator push with number matching	Permitted	Not phishing-resistant. Acceptable in current state; retired for enforced populations in target state.
A third-party authenticator app	Permitted — current state only	Retire with the third-party identity provider. Any procedure or guide referencing it must be reviewed at cutover.
SMS or voice call	Discouraged; prohibited in target state	Interceptable. Permitted today only as a fallback where no other method is possible, and recorded as an exception.
Email to a personal address	Prohibited	Never an approved factor, in either state.
Security questions	Prohibited	Answers are discoverable. Not to be enabled as an SSPR method.

5.3 Enrollment procedure — account holder

1. Sign in with the credential issued per ACC-01 §5.2, on a device you control.
2. When prompted for security information, register the highest-ranked method in §5.2 that your device supports.
3. Register a second, different method. Two methods on the same phone is one method with extra steps — if that phone is lost you have lost both.

4. Record nothing about your methods in a shared document, ticket or email.
5. If you replace or lose a device, remove the old method and register the new one before you dispose of the old device. Doing it in that order avoids section 6 entirely.

5.4 Enrollment where the person has no working device

Verify identity per section 6, then issue a Temporary Access Pass rather than a password. A TAP is time-bound, single-purpose and forces method registration at sign-in, so no reusable shared secret is created. Record the TAP issue on the ticket, including who authorised it and which verification tier was used.

---

6. Identity verification before any account action — mandatory gate

> **The rule**
> No password reset, MFA method removal, TAP issue, or access change is performed until the requester's identity has been verified by one of the tiers in §6.2, and the tier used has been recorded on the ticket.
> The verification tier is a required field. A ticket closed without it is an incomplete ticket, regardless of whether the request was genuine.

This section exists because of a common event: a request to complete MFA sign-in arrives at the service desk from a personal email address, naming a different person as the account holder. Whether or not that particular request is legitimate is beside the point — without this section, the process has no step at which it would be caught.

6.2 Verification tiers

Tier	Method	What it requires	Use when
T1	In person	Government or organization photo ID presented at the service desk, checked against the directory record.	Default and strongest. Always preferred for privileged accounts.
T2	Live video call	Camera on, face visible, photo ID held to camera, plus two directory facts the requester supplies unprompted (HR/client record ID, department, manager name, device asset tag). The staff member records which facts were used.	Remote staff, staff and remote users. Standard remote path.
T3	Vouching by a known party	The requester's manager or department head confirms identity from their own organization account, on the ticket. The voucher must themselves already be signed in.	The requester cannot do T1 or T2 — no camera, no ID to hand.
T4	Callback to the directory number	Call the number in the directory record, not a number the requester supplies. Combine with two directory facts.	Fallback only, and never on its own for a privileged account.

Privileged accounts (ACC-07) require T1 or T2. No exceptions, and no vouching.

6.3 Requests that are never actioned

- Any request arriving from a non-the organization email address, including one that names the account holder correctly.
- Any request made by a third party on the account holder's behalf, unless that third party is the manager using T3 and the account holder is separately contactable.
- Any request where the requester supplies the verification facts only after being told what is needed. Facts must be volunteered, not prompted.
- Any request under time pressure that also declines verification. Urgency is the standard pretext; treat it as a signal rather than a reason.
- Any request to add a new MFA method while an existing method remains registered and reachable — remove the old one via §5.3 instead. Where a request is declined, tell the requester which verification path is available to them and offer to arrange it. The answer is "here is how we can do this", not "no".

---

7. Password reset

7.1 Self-service — target state, and the highest-leverage change available

Entra self-service password reset lets a person who has two registered methods reset their own password with no service desk involvement. Against the lockout volume you measured in §1, this is the single control with the largest effect on queue volume.

1. Enable SSPR for a pilot group first, not the whole tenant. Confirm the reset actually completes for a real account before widening.
2. Require two registered methods. One method means one lost phone becomes a service desk ticket anyway.
3. Do not enable security questions as a method (§5.2).
4. Enable password reset from the Windows sign-in screen for Entra-joined devices, so a person locked out of their laptop is not dependent on a second device.
5. Publish the reset address to end-users through GOV-05, and put it in the mail signature of every service desk reply about access.
6. Widen by account class in the wave order of §11, measuring assisted-reset volume at each step. A control that does not move the number is not working, and that is worth knowing early.

7.2 Assisted reset — current state, and the fallback in target state

1. Verify identity per section 6 and record the tier.
2. Confirm the account is not disabled, unlicensed or blocked by policy rather than by password. Section 8 distinguishes these; resetting a password that was never the problem is the commonest wasted action in the queue.
3. Where the platform supports it, issue a Temporary Access Pass rather than a temporary password. A temporary password does not expire on use and will still work weeks later.
4. Where a temporary password must be used, require change at next sign-in, and deliver it in person, by T2 video, or to the manager. Never to a personal address, and never in the ticket body.

5. Confirm with the person that they have signed in successfully before closing. A reset is not the outcome; access is.
6. Record: verification tier, method used, who authorised, and confirmation of successful sign-in.

8. Lockout triage

“I’m locked out” describes a symptom with at least five distinct causes, each with a different fix. Treating them all as password resets is how a few hundred real lockouts become twice as many tickets.

Cause	How it presents	How to confirm	Correct action
On-premises AD lockout from repeated bad passwords	Sign-in fails immediately, everywhere, including on-site.	AD account lockout flag; bad-password count.	Unlock. Then find the source — a stale credential on a phone or mapped drive is the usual cause, and resetting the password alone will not stop it recurring.
Entra smart lockout	Fails from one location or client but works from another.	Entra sign-in logs show the smart-lockout result.	Wait out the lockout or unlock. Investigate the source IP; a burst from an unfamiliar address is a §10 matter.
MFA method unavailable — lost, replaced or wiped device	Password accepted, then the second factor never arrives or the app has no account in it.	Ask what changed about their phone. Almost always a new or reset device.	Verify per §6, then re-register per §5.4. Do not reset the password — it is not broken.
Conditional Access or risk-based block	A clear policy message, or failure only from a specific device, network or app.	Entra sign-in log names the policy or the risk detection.	Resolve the condition — device compliance, location, risk. A reset will not clear it and will mask the cause.
Not a lockout at all	Sign-in succeeds; a specific application or portal denies access.	Check licence assignment, group membership, and the application itself.	Licence (M365-20), group (M365-04), or application (ACC-16). Reclassify the ticket.

Record the confirmed cause on every lockout ticket, using these five categories. Within a few months that turns an undifferentiated lockout count into a ranked list of fixable root causes — which is the only way the number comes down rather than moving around.

9. Repeat-incident and compromise escalation

A typical case: an account is blocked for the third time in a few months. The person is told not to use a VPN or share access, and IT intends to notify their manager and IT Security. That is the right instinct, and this section makes it a standing ladder rather than a judgement call each time.

Occurrence	Action	Who decides	Recorded where
1st	Restore per §7 or §5.4. Record the confirmed §8 cause. Brief the person on credential sharing (ACC-15).	Service desk	Ticket
2nd within 90 days	Restore, then review sign-in history for shared-credential or unfamiliar-location patterns. Require re-registration of all MFA methods. Flag the account for watch.	Service desk, IT Security informed	Ticket + watch list
3rd within 90 days	Treat as suspected compromise or credential sharing until shown otherwise. Force password reset, revoke all sessions, remove and re-register every method. Notify the account holder's department head or manager in writing.	IT Security decides; Head of IT informed	Ticket + security record
Confirmed sharing or sale of credentials	Suspend per ACC-13. Refer to the department head or HR. Do not restore access until the referral concludes.	Head of IT approves; IT Security executes	Security record + referral
Confirmed compromise by a third party	Declare an incident under GOV-03. Preserve sign-in and mailbox audit data before remediating.	IT Security declares	Incident record

"Told not to use VPN or provide access to anyone" must also exist as a published rule the organization can point to, not only as verbal guidance in the moment. Most organizations already have an acceptable use policy; ACC-15 should confirm it explicitly covers credential sharing and VPN misuse and then make it the document the desk cites, rather than writing a new one.

10. Risky sign-in and impossible travel

Where a managed detection partner or Entra raises a risky sign-in — impossible travel, unfamiliar sign-in properties, anomalous token use — the account is locked pending review. That is correct, and it also means an alert has an end-user consequence, so the two halves need to run together.

1. Confirm the detection in the Entra sign-in logs and note the IP, location, device and application.
2. Preserve the evidence before remediating. Once sessions are revoked and the password is changed, the trail is harder to reconstruct.
3. Contact the account holder through a channel independent of the account — directory phone number, or their manager. Not the mailbox in question.
4. Verify identity per section 6 before restoring anything.
5. Where the sign-in is confirmed as the account holder travelling, document it and restore. Where it is not, treat it as confirmed compromise and go to §9.
6. Where several accounts show the same source IP granted authentication — treat it as one investigation, not several tickets. Notify IT Security and open a single record.
7. Close the loop with the partner case so the external record matches the internal one.

11. Phishing-resistant MFA rollout — how not to repeat the setup loop

> **What usually goes wrong**
>
> A rushed rollout of phishing-resistant MFA breaks access and leaves people stuck in an MFA setup loop. The mechanism is well understood and entirely avoidable: a Conditional Access policy requiring phishing-resistant authentication was in scope for the security-information registration endpoint itself.
>
> The user then cannot register a phishing-resistant method, because registering one requires a completed authentication, and the only authentication the policy will accept is with a method they do not yet have. That is the loop. It is not a user error and no amount of guidance documentation fixes it.

11.1 Rules that prevent it

- Conditional Access guards sign-in, never the registration flow. Scope the authentication-strength policy to resources, and exclude the registration endpoint.
- Every user in an enforced wave must already hold a registered phishing-resistant method before the policy moves out of report-only. Enforcement follows registration; it never drives it.
- A person who has lost everything is recovered with a Temporary Access Pass, which satisfies the requirement long enough to register a real method. Without TAP configured, total-loss recovery has no exit and becomes a second loop.
- Break-glass accounts are excluded from every enforcement policy, and their exclusion is tested before the first wave.
- Waves are scoped by device platform, because platform support is the real constraint. A user on an OS below the passkey minimum in §5.2 needs a FIDO2 key, and that must be in hand before their wave, not ordered after they are blocked.

11.2 Wave sequence

Wave	Population	Rationale	Gate to proceed
0	IT staff and administrative accounts	The people who will support everyone else should hit the problems first. Privileged accounts also carry the highest risk.	All §3 cutover conditions met for this group.
1	Staff facing an external deadline	A vendor that enforces phishing-resistant MFA by a date. This wave is date-driven, not readiness-driven, which makes its gate more important, not less.	Registration complete; report-only clean for 10 business days; FIDO2 keys in hand for any unsupported device.
2	Remaining full-time staff, by platform	Largest population with predictable, managed devices.	Per-platform readiness report; Wave 1 assisted-reset volume flat or falling.
3	Part-time and contract staff	Shorter engagements, less managed devices, more personal hardware.	Wave 2 complete; FIDO2 stock confirmed.
4	End users, by platform	Usually the largest and least managed population. Also where lockouts concentrate, so the biggest prize and the biggest risk.	Waves 0–3 complete; SSPR live and measurably reducing assisted resets.

11.3 Measures that tell you it is working

- Share of accounts in each wave with a registered phishing-resistant method.
- Share of sign-ins satisfied by a phishing-resistant method.
- Assisted password resets per week, against the baseline you measured in §1.
- Lockout tickets per week, by confirmed §8 cause.
- Total-loss recovery events, and median time to restore. Publish these to the Head of IT monthly. The §1 measurement is the baseline; without it a later claim of improvement cannot be substantiated.

12. Service levels

Request type	Target
Self-service reset	Immediate, no ticket
Assisted reset, identity verified	1 business hour from completed verification
MFA method re-registration after device change	1 business hour from completed verification
Total-loss recovery (all methods lost)	4 business hours from completed verification
Lockout triage to confirmed cause	1 business hour
Risky sign-in — account holder contacted	1 business hour of the alert
Suspected compromise escalated to IT Security	30 minutes of the third occurrence or first confirmation

Proposals for ratification under GOV-06, not commitments currently in force.

13. Records

Record	Held in	Retention
Verification tier used, and facts relied on	Service desk ticket — required field	3 years
Confirmed §8 lockout cause	Service desk ticket — required field	3 years
TAP issue: who authorised, why, tier used	Ticket + Entra audit log	3 years
MFA method removals, with reason	Ticket + Entra audit log	3 years
Repeat-incident watch list	IT Security record	Rolling 12 months
Wave readiness and report-only evidence	Project record	Life of the migration + 2 years
Monthly measures to Head of IT	Project record	3 years

14. Related documents

ID	Title	Relationship
ACC-01	Account Lifecycle: Joiner, Mover, Leaver	Creates the identity and sets the enrollment deadline this procedure enforces.

ID	Title	Relationship
ACC-04	Password Standard & Self-Service Password Reset	Password composition and the SSPR configuration referenced at §7.1.
ACC-05	Account Lockout Triage & Repeat-Incident Escalation	Expands §8 and §9 into full desk-level detail.
ACC-06	Identity Verification Before Any Account Action	Section 6 is the summary; ACC-06 is the full standard and the training material.
ACC-07	Privileged & Administrative Account Standard	Stricter method and verification requirements for admin accounts.
ACC-13	Account Suspension for Misuse or Policy Investigation	Destination of the §9 sharing pathway.
ACC-15	Acceptable Use & Credential-Sharing Standard	The published rule §9 relies on. Aligns to your existing acceptable use policy rather than replacing it.
ACC-16	Application Onboarding, SSO & SAML Claims Standard	How an application consumes the authentication strength set here — including any vendor with its own MFA requirement.
DEV-01 / DEV-02	Device Enrollment / Compliance Baseline	Windows Hello for Business and platform credentials depend on device join and compliance.
DEV-16	Lost, Stolen or Compromised Device Response	Runs alongside §5.3 and §10 when the device itself is the loss.
GOV-03	Security Incident Response & Escalation Matrix	Where §9 and §10 escalate to.
GOV-05	Knowledge Base Article Standard	Format for the end-user guide derived from Appendix C.
GOV-06	SLA Definition, Priority Matrix & Escalation	Ratifies §12.

Appendix A — Help desk verification script

Read this, in order, before any account action. Record the tier and the facts relied on.

#	Say / do
1	“Before I can make any change to the account, I need to verify who I’m speaking to. I can do that in person at the service desk, or on a short video call — whichever is easier for you.”
2	If the request arrived from a non-the organization address: “I can’t action a request from an outside address, but I can help you directly. Are you able to join a quick video call?” Do not proceed on the email thread.
3	On video: “Please turn your camera on and hold your photo ID up to the camera.” Check the name and photo against the directory record.
4	“Without me prompting you, can you tell me two of the following: your HR/client record ID, your department, your manager’s name, or the asset tag on your organization laptop.” Do not list which one you are expecting. Note which facts they gave.

#	Say / do
5	If they cannot: “I can accept confirmation from your manager instead. May I copy them on this ticket?” That is Tier 3, and the manager must reply from their own organization account.
6	Before acting, check: is the account actually disabled, unlicensed, or blocked by policy rather than by password? Run Appendix B first.
7	Act. Prefer a Temporary Access Pass over a temporary password.
8	Record on the ticket: verification tier, facts relied on, action taken, confirmed §8 cause.
9	Confirm the person has signed in successfully. Then close.

If anything about the request feels wrong — urgency plus refusal to verify, a third party pressing on someone’s behalf, facts supplied only after prompting — stop and escalate to IT Security. You will never be criticised for verifying.

Appendix B — Lockout triage card

Ask	Answer	Then
1	Does the sign-in fail everywhere, immediately, including on site?	Yes → AD lockout. Unlock, then hunt the stale credential.
2	Does it work from one place or client but not another?	Yes → Entra smart lockout. Check the source IP; unfamiliar burst → §10.
3	Is the password accepted but the second factor never arrives?	Yes → MFA method problem. Verify per §6, re-register per §5.4. Do NOT reset the password.
4	Did they get a specific policy or compliance message?	Yes → Conditional Access or risk block. Read the sign-in log; fix the condition, not the password.
5	Does sign-in succeed but one app or portal deny access?	Yes → not a lockout. Licence, group, or application. Reclassify the ticket.
6	Has this account been here before in the last 90 days?	Yes → go to the §9 ladder before restoring.

Appendix C — End-user quick reference

Source text for the published guide. Format per GOV-05 before publishing.

If...	Do this
You forgot your password	Use the self-service reset link in any IT email signature or on the IT pages. It works without contacting anyone, provided you registered two methods.
You are getting a new phone	Register a method on the new phone BEFORE you wipe or trade in the old one. This takes two minutes and avoids everything below.

If...	Do this
You already lost the phone with your only method	Contact the service desk. You will be asked to verify your identity in person or on a short video call with photo ID. This is not a formality and cannot be waived.
You think your account has been accessed by someone else	Contact the service desk immediately and say so explicitly. Do not change the password first — IT needs to see the sign-in trail before it changes.
Someone asks for your password or an MFA code	Never provide it. IT will never ask for either. Report the request to the service desk.
You are locked out and it is urgent	Say so, and still expect to verify. Urgency is the most common pretext used against help desks, so the verification step applies especially when time is short.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.